

Sam Rutherford
BSc (Hons) Ethical hacking

Introduction

The use of botnets to orchestrate devastating DDoS attacks has been felt with infamous attacks such as the Mafiaboy attack in 2000 or the 2016 Dyn attack which utilised the Mirai botnet.

Mirai is a botnet and malware which began as a Minecraft DDoS protection racketeering scam. What makes Mirai so effective in performing DDoS attacks is the sheer number of bots it has. Mirai specifically targets low level IoT devices.

Mirai aims to exploit one of the most common universal flaws of default credentials by performing a dictionary attack using the top 60 most common default credentials found within IoT devices.

Aim

The aim of this honours project was to firstly perform a malware analysis on Mirai to evaluate how it performs its device scanning and connection. This would be achieved through static code analysis. A dynamic malware analysis also took place to find ways for detecting Mirai on an infected device. Literature review was also performed alongside this.

Using the literature review and malware analysis, a tool was developed, known as Rekishi. This tool was able to:

- Automatically discover devices within the network.
- Assess the vulnerability of the devices by using the wordlist used by Mirai and connect to the devices.
- Perform device hardening and detection of Mirai
- Remove Mirai from infected devices.

Method

The malware analysis was effective in providing insight into how Mirai achieves its goals:

- The TCP handshake is used to discover devices.
- Telnet is used to connect to the device and uses the top 60 most common IoT credentials
- When a device is infected, a socket is opened on port 48101.

The literature review suggested certain device hardening methods such as changing the ports, which prevented Mirai connection. Additionally, removing the Mirai infection is as simple as disconnecting the device from the network and rebooting.

```
remnux@remnux:~$ netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address
tcp        0      0 127.0.0.1:48101
tcp        0      0 127.0.0.1:53
udp        0      0 127.0.0.1:53
udp        0      0 192.168.110.128:68

remnux@remnux:~$ netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address
tcp        0      0 127.0.0.1:48101
tcp        0      0 127.0.0.1:53
udp        0      0 127.0.0.1:53
udp        0      0 192.168.110.128:68

remnux@remnux:~$
```

Figure 1: Netstat output of the before and after of Mirai running.

The developed artefact used the knowledge from the literature review and analysis to complete the aims. The artefact employs numerous scanning methods such as the one found within Mirai. The same wordlist is used for assessing device vulnerability. Finally, Telnet or SSH are used for the device hardening, detection and removal of Mirai.

IP address	MAC address	Username	Password	Vulnerable	Sudo level
192.168.110.128	00:0C:29:96:87:2B	None	None	None	None
192.168.110.130	00:0C:29:06:D2:50	admin	admin	True	True
192.168.110.131	00:0C:29:EA:ED:A8	admin1	password	True	True
192.168.110.132	00:0C:29:13:36:1A	root	xc3511	True	True
192.168.110.254	00:50:56:E7:6D:54	None	None	None	None

Figure 2: Command line output of the artefact displaying the device, the username and password identified, if it's vulnerable and the level of the credentials found.

Results

The purpose of the testing was to evaluate the effectiveness of the various aims the tool attempted to fulfill.

The testbed utilised various VMs differing in complexity, such as the Raspberry Pi and Ubuntu server aiming to simulate IoT devices within a virtual network.

The scanning methods used discovered all devices with varying levels of time to complete, with the TCP handshake method taking the most time.

The vulnerability assessment was also successful on the devices where the devices was expected to be vulnerable, with only the Ubuntu server VM having inconsistencies.

Device	Password hacking	
	Expected outcome	Actual outcome
192.168.110.128	Not compromised	Not compromised
192.168.110.130	Compromised	Compromised
192.168.110.131	Compromised	Sometimes
192.168.110.132	Compromised	Compromised

Table 1: Results for the vulnerability assessment

The hardening which took place as successfully implemented and was also able to block any connection attempts made using Telnet or SSH due to the port changes.

The Mirai detection and removal was successful in detecting the infected device, by correctly alerting the user and removing the infection but did not always successfully perform the check, as seen on the Ubuntu server.

Device	Mirai detection and removal	
	Expected outcome	Actual outcome
192.168.110.128	N/A	N/A
192.168.110.130	Detected and removed	Detected and removed
192.168.110.131	Not detected	Failed
192.168.110.132	Not detected	Not detected

Table 2: Results for the detection and removal of Mirai

Discussion

The TCP sweep was found to be extremely slow when scanning networks but was the fastest when scanning singular hosts.

Device dictionary attack was effective in proving if a device was vulnerable to Mirai, however a more advanced wordlist may be used by mutations of Mirai, meaning this method isn't future proof and a more comprehensive word list could be utilised.

During the literature review, there were conflicting sources about methods of identifying Mirai, mainly the port which was open. One paper described that port 23 is used for CnC communication while another described it to be any TCP port, while none mentioned viewing port 48101. An issue with viewing port 23 is that this is the default port for Telnet which would lead to many false positives if determining infection was based on that.

The detection and removal failed on the Ubuntu server due to the device being too low level.

Conclusion

The developed artefact was successful in achieving the goals of the project but there is room for improvement.

Performing further dynamic analysis including setting up the CnC servers would be performed if given more time.

References

Frank, C et al. (2018). Protecting IoT Devices from the Mirai Botnet. Journal of Information Systems Applied Research (pp. 33-44). ISCAP. Retrieved from <https://jisar.org/2018-11/n2/JISARv11n2p33.pdf>